ACTIVIDAD FFEOE

Cristóbal Suárez Abad

SEGURIDAD Y ALTA DISPONIBILIDAD - 2º ASIR

Índice

Memoria Técnica: SAD en el Entorno de Prácticas 2
Bloque 1: Estrategia y Perímetro de Seguridad 3
1.1. La Triada de la Seguridad (RA1.a) 3
1.2. Seguridad Física vs. Lógica (RA1.b) 4
1.3. Protección Perimetral (RA1.h) 5
Bloque 2: Vulnerabilidades y Factor Humano 6
2.1. Gestión de Vulnerabilidades (RA1.c) 6
2.2. Ingeniería Social (RA1.d) 6
2.3. Políticas de Contraseñas (RA1.e) 7
Bloque 3: Tecnologías de Protección y Respuesta 8
3.1. Sistemas Biométricos (RA1.f) 8
3.2. Criptografía Aplicada (RA1.g) 8
3.3. Análisis Forense e Incidentes (RA1.i) 9

Memoria Técnica: SAD en el Entorno de Prácticas

Extensión máxima: 5 páginas (contando enunciado)

Objetivo: Analizar la implementación real de las políticas de seguridad en un entorno profesional y contrastarlas con los conocimientos teóricos adquiridos.

Instrucciones

Durante tu estancia en la empresa, deberás completar este documento analizando los puntos que se detallan a continuación.

- **Si el punto se aplica en tu empresa:** Describe cómo lo hacen (herramientas, protocolos, software, etc.).
- **Si el punto NO se aplica:** Elabora una **propuesta técnica** detallada sobre cómo crees que debería implementarse para mejorar la seguridad de tu centro de prácticas.

Bloque 1: Estrategia y Perímetro de Seguridad

1.1. La Triada de la Seguridad (RA1.a)

Describe cómo la empresa garantiza los tres pilares fundamentales de la información:

- **Confidencialidad:** ¿Quién accede a qué?

- **Cámaras de Seguridad:**
    - Altos cargos de la empresa.
    - Jefe de IT.
        - Dos empleados más de IT.
- **Servidores (inventario, facturación, etc):**
    - Empresas externas que dan el servicio (Proactivanet[1], etc)
    - Jefe de IT.
        - Dos empleados más de IT.
- **Servidores secundarios (Servidores VMs de Windows Server → Sesiones remotas para empleados, etc):**
    - Solo el Departamento de IT.
- **Controles de acceso:**
    - Hay un empleado de IT que se encarga en exclusiva de esa tarea, aunque se entiende que sus jefes también tendrán acceso.
- Bases de datos:
    - Los empleados solo pueden acceder a las correspondientes a sus departamentos y puestos.

[1] https://www.proactivanet.com/

- **Integridad:** ¿Cómo evitan que los datos sean alterados sin permiso?

- Se siguen las reglas de permiso mínimo.
- Existen sistemas de alerta para detectar tráfico inusual o masivo. En una ocasión, cuando Sergio necesitó transferir datos mediante FTP u otro protocolo, se generó una advertencia automática al responsable, quien, tras verificar la acción con él, procedió a autorizarla.
- Uso de certificados digitales.
- Correos digitales con firma de la empresa.

- **Disponibilidad:** ¿Qué medidas hay para que el sistema no pare (Backups, SAIs, etc.)?

- Todos los servidores tienen sistemas de monitorización en tiempo real (hay un monitor en la sala del Departamento que muestra los datos, se usa Grafana).
- Backups periódicos de los servidores.
- SAIs para los servidores. También existen generadores auxiliares para el resto de las instalaciones.

1.2. Seguridad Física vs. Lógica (RA1.b)

Identifica las diferentes medidas de seguridad que encuentras en el centro de trabajo:

- **Física:** Medidas de acceso al CPD, cámaras, cerraduras, protección contra incendios...

- Existen dispositivos de control de acceso para la entrada, diferentes alas de cada planta y también para zonas más específicas, como por ejemplo el Departamento de Informática y el CPD que se encuentra en su interior.
- Todos los recintos están monitorizados a través del sistema de vigilancia, excepto algunos que tengan información sensible (Altos cargos, departamento de IT, Administración, etc).
- Tienen extintores de incendios en sitios estratégicos y sistemas de extinción específicos para CPDs (gases inertes que extinguen las llamas sin dañar el hardware).

- **Lógica:** Antivirus, firewalls, permisos de usuario, segmentación de redes.

- Antivirus (todos los equipos de los empleados tienen un antivirus instalado, actualmente usan Panda).
- La administración de los permisos de cada usuario/grupo se hace mediante políticas de grupo con Active Directory (en esta empresa se usa el Active Directory de Microsoft).
- Los departamentos tienen cada uno sus VLANs para segmentar la red de la empresa.
- En ciertos departamentos se usa el filtrado por MAC para la conexión por Ethernet.
- Se usa software para la detección de phishing y correos spam.
- Uso extenso de firewalls (en nuestro departamento se usa un firewall en la propia VLAN, así que entiendo que también usaran otro para el exterior).

1.3. Protección Perimetral (RA1.h)

Analiza el plan de protección frente a redes públicas (Internet). ¿Existe un firewall físico? ¿Se utilizan zonas desmilitarizadas (DMZ)? ¿Cómo se gestionan las conexiones externas?

Nosotros no disponemos de acceso a esa información, pero como he comentado antes, en nuestra propia VLAN conozco la existencia de un firewall físico, en concreto uno de la empresa Check Point (lo sé por la MAC "00-1c-7f-81-07-0a"[2]).

No sé si tienen configurado una DMZ, aunque teniendo en cuenta lo bien segmentadas que están las VLAN de los diferentes departamentos, no me extrañaría.

En cuento a las conexiones externas, se porque he configurado varios portátiles de la empresa, que usan software de Check Point[3].

[2] https://www.ipchecktool.com/tool/macfinder
[3] https://www.checkpoint.com/

Bloque 2: Vulnerabilidades y Factor Humano

2.1. Gestión de Vulnerabilidades (RA1.c)

Clasifica las principales vulnerabilidades que detectes en el sistema de la empresa según su origen (software desactualizado, falta de parches, hardware antiguo, configuración incorrecta).

La más grave que encuentro sería la de permitir el uso de memorias USB (tienen una plantilla GPO para testeo, pero de momento no se ha instaurado a ningún departamento).

Por otra parte, aún existen varias decenas de equipos desactualizados (Windows 10) que requieren la inmediata actualización a Windows 11.

Creo que la vulnerabilidad más importante puede venir por parte de algún error por parte de los empleados (victimas de técnicas de phishing, etc).

2.2. Ingeniería Social (RA1.d)

¿Ha sufrido la empresa algún intento de phishing o fraude? ¿Existe concienciación entre los empleados? Describe qué medidas se toman para evitar que el personal caiga en engaños informáticos.

No se trató exactamente de un intento de phishing, pero hace algunos años sufrieron un ataque a través del correo electrónico. El malware logró propagarse por el sistema, y los técnicos tardaron aproximadamente tres días en resolver la incidencia.

Si existe una gran concienciación. La empresa es considerada de importancia estratégica por la Unión Europea y obliga a este tipo de empresas a tener al 100% de sus empleados con formación sobre ciberseguridad. Nosotros (los alumnos en práctica) hemos asistido a esas clases y se hace un buen resumen de las principales amenazas y protocolos a seguir por parte de los empleados. Además, los empleados reciben “píldoras”, que son cuestionarios por email que deben responder y son obligatorios.

2.3. Políticas de Contraseñas (RA1.e)

Describe la normativa interna: longitud mínima, caducidad, uso de Doble Factor de Autenticación (2FA) y si se utiliza algún gestor de contraseñas corporativo.

Las políticas de contraseña son:

- Longitud mínima (aunque desconozco cuanto es el mínimo).
- Caracteres especiales.
- Tienen caducidad.

Para las cuentas de Microsoft se usa un sistema de autenticación de dos pasos (2FA).

No se hace uso de gestores de contraseñas (no son seguras al guardar las contraseñas en texto plano).

Bloque 3: Tecnologías de Protección y Respuesta

3.1. Sistemas Biométricos (RA1.f)

¿Se utiliza la biometría (huella, reconocimiento facial) para el acceso a las instalaciones o a los dispositivos? Si no es así, justifica si sería ventajoso implantarlo en algún área específica.

Los dispositivos de acceso son sistemas capaces de usar la biometría (creo que en este caso solo reconocimiento facial), pero actualmente no se usa (aunque en el pasado se usó durante un tiempo). Se dejó de usar debido a normativas de la Unión Europea.

Actualmente solo se usan tarjetas identificativas en estos dispositivos de control de acceso.

Si la Unión Europea fuese menos estricta, sería ventajoso para el acceso a zonas sensibles como los CPD. La ventaja sería que es más difícil robar una cara que una tarjeta identificativa.

3.2. Criptografía Aplicada (RA1.g)

Identifica el uso de la criptografía en:

- **Almacenamiento:** ¿Se cifran los discos duros o bases de datos?

No, no se hace nunca en esta empresa. Ante la pérdida de la contraseña es casi imposible la recuperación de datos por parte de los técnicos.

- **Transmisión:** ¿Qué protocolos se usan para el envío de datos (HTTPS, VPN, SSH, SFTP)?

Para la conexión a sesiones remotas de Windows (ya sea Server o Windows 11) se usa RDP (puerto 3389 TCP).

Los usuarios del Active Directory tienen configurados varias unidades de almacenamiento en red mediante SMB 3.0 (TCP 445).

Los técnicos de IT usan mucho AnyDesk para conectarse a los equipos de empleados y resolver incidencias (TCP 80, 443, 6568).

Las impresoras en red (9100).

También se usan los propios de SSH (22), IMAPS (993), etc.

3.3. Análisis Forense e Incidentes (RA1.i)

En caso de un ataque o brecha de seguridad, ¿conoces las fases que sigue la empresa? (Identificación, preservación de evidencias, análisis de logs, recuperación). Si no tienen un protocolo, diseña un esquema básico de respuesta ante incidentes para ellos.

En el curso de ciberseguridad al que fuimos, el que mencioné antes, hicieron hincapié en estos pasos:

- Desconectar cable Ethernet (o desactivar Wi-Fi).
- No apagar el equipo (es vital para evitar el borrado de logs y otras evidencias que permitan identificar el tipo de malware).
- Avisar a los técnicos de IT. A partir de aquí los técnicos toman el control.
- Estos avisarán a organismos como el INCIBE y se tomarán las medidas necesarias para resolver la situación.